GÜVENL■K VE TEHD■T MODELLEME RAPORU

Ürün: Teknoloji Beceri Talep Radar■ & Canl■ Etiket Atlas■
Canl■ Da■■t■m URL: https://teknoloji-radari.muhammedeyupcatan.workers.dev
GitHub Deposu: https://github.com/eyupcatan/teknoloji-radari
Ö■renci: Muhammet Eyüp Çatan · **Ö■renci No:** 2516016025
Ö■retim Eleman■: Ö■r. Gör. Osman Can Çetlenbik · **Dönem:** 2026-2027 Güz

1. Yönetici Özeti

Kullan■c■ Arayüzü Tasar■m■ dersinde geli■tirilen canl■ veri ürünü (Stack Overflow teknoloji etiketleri a■■), bu sprint kapsam■nda Cloudflare Workers ve Static Assets tabanl■ sunucusuz (serverless) bir mimariye ta■■nm■■t■r. Ki■isel ödev kart■nda tan■mlanan birincil tehdit olan **ReDoS (Regular Expression Denial of Service)** ve a■■r■ büyük girdiyle metin i■leme hatt■n■n kilitlenmesi senaryosuna kar■■ 3 katmanl■ savunma hatt■ kurulmu■tur: (1) 10 KB girdi boyut s■n■r■, (2) sabit RE2 uyumlu O(N) lineer regex katalo■u ve (3) 2.000 ms i■lem zaman a■■m■. Yap■lan do■rulama testlerinde 29 karakterlik kötü niyetli bir girdide korumas■z sistemin **4.292 ms (4,3 saniye)** boyunca kilitlendi■i, korumal■ sistemin ise ayn■ girdiyi **0.05 ms'nin alt■nda** güvenle i■ledi■i kan■tlanm■■t■r. Sistem 0 TL bütçe hedefiyle yap■land■r■lm■■, CSP (unsafe-inline/eval içermeyen), HSTS ve RFC 9116 güvenlik ba■l■klar■yla sertle■tirilmi■tir.

2. Bulut Mimarisi ve Güven S■n■rlar■ (IaC)

Altyap■ Kod Olarak (IaC) wrangler.jsonc üzerinden tan■mlanm■■t■r. Mimari bile■enler ve güven s■n■rlar■ a■a■■daki veri ak■■ diyagram■nda özetlenmi■tir:

Bile■en	Konum / Katman	Güven S■n■r■ & Güvenlik Kontrolleri
Kullan■c■ Taray■c■s■	■nternet (D■■)	Güvensiz Bölge. TLS 1.3 zorunlu, HSTS aktif.
Cloudflare Edge / CDN	Bulut Kenar■ (Edge)	DDoS korumas■, SSL/TLS sonland■rma, HSTS/WAF.
Worker V8 Sandbox	Serverless Fonksiyon	■zole V8 çal■■ma ortam■. Girdi boyutu & zaman a■■m■ kontrolü.
Static Assets	Workers Asset Binding	Salt okunur canl■ veri ürünü (HTML/JS/CSS/JSON).
GitHub Actions CI/CD	DevSecOps Hatt■	En az yetki (permissions: read), gitleaks ve OSV-Scanner.

3. Ki■isel Güvenlik Kontrolü: ReDoS ve Dayan■kl■ Metin ■■leme

Tehdit Tan■m■: Standart JavaScript regex motoru (V8), NFA (Nondeterministic Finite Automaton) geri izleme algoritmas■n■ kullan■r. ■ç içe geçmi■ niceleyiciler içeren kal■plara (ör. (a+)+$) e■le■meyen kötü niyetli girdi verildi■inde karma■■kl■k O(2^N) üstel seviyeye f■rlar ve sunucu thread'i kilitlenir.
Uygulanan 3 Katmanl■ Kontrol:
1. **Girdi Boyut S■n■r■:** ■stek gövdesi maksimum 10 KB ile s■n■rland■r■lm■■t■r; a■an istekler 413 koduyla an■nda reddedilir.
2. **Güvenli Regex (RE2 Uyumlu):** Dinamik regex olu■turma yasaklanm■■, yaln■zca O(N) lineer zamanda çal■■an sabit kal■plar tan■mlanm■■t■r.
3. **■■lem Zaman A■■m■:** Promise.race mekanizmas■yla regex i■leme 2.000 ms ile s■n■rland■r■lm■■, kilitlenmelere kar■■ güvenlik a■■ kurulmu■tur.

Do■rulama Testi Ölçümleri (Önce / Sonra):

A■ama / Senaryo	Girdi / Kal■p	■■lem Süresi	Sonuç & Güvenlik Durumu
ÖNCE (Korumas■z)	12 char (a...!)	0.48 ms	Dü■ük gecikme
ÖNCE (Korumas■z)	20 char (a...!)	14.87 ms	Gecikme art■■■
ÖNCE (Korumas■z)	24 char (a...!)	134.62 ms	Yüksek CPU tüketimi
ÖNCE (Korumas■z)	27 char (a...!)	1,045.48 ms	Kritik yava■lama (> 1 sn)
ÖNCE (Korumas■z)	29 char (a...!)	4,292.98 ms	■ K■L■TLEND■ (Event Loop Blokaj■)
SONRA (Korumal■)	Gerçek Etiket: 'http'	0.27 ms	■ GÜVENL■ (Do■rusal O(N))
SONRA (Korumal■)	Gerçek Etiket: 'postgresql'	0.06 ms	■ GÜVENL■ (Do■rusal O(N))
SONRA (Korumal■)	29 char Kötü Niyetli Girdi	< 0.05 ms	■ GÜVENL■ (Geri izleme önlendi)
SONRA (Korumal■)	25 KB A■■r■ Boyut Sald■r■s■	< 0.05 ms	■■ ENGELLEND■ (413 Payload Too Large)
SONRA (Korumal■)	Bilinmeyen Kal■p ■ste■i	< 0.05 ms	■■ ENGELLEND■ (400 Bad Request)

4. Tehdit Modeli (STRIDE Analizi)

Sistem üzerinde belirlenen 8 temel tehdit, risk puanlar■ (Olas■l■k × Etki) ve al■nan önlemler:

#	Tehdit Ad■	Kategori	Risk	Al■nan Güvenlik Önlemi	Kalan Risk
T1	ReDoS Sald■r■s■	Denial of Service	20/25	10 KB girdi s■n■r■, RE2 kal■plar■, timeout	Çok Dü■ük
T2	API Anahtar■ S■z■nt■s■	Info Disclosure	15/25	Kasada anahtarlar, gitleaks, CI taramas■	Dü■ük
T3	XSS Sald■r■lar■	Tampering / Info	12/25	Kat■ CSP (unsafe-inline yok), HTML escape	Çok Dü■ük
T4	Yetkisiz Deploy	Elevation of Priv.	10/25	En az yetki (permissions: read), token kontrolü	Dü■ük
T5	Tedarik Zinciri Aç■■■	Tampering	8/25	npm audit, OSV-Scanner, Dependabot	Dü■ük
T6	Clickjacking	Tampering	6/25	X-Frame-Options: DENY, frame-ancestors: 'none'	Yok
T7	API A■■r■ Yükleme	Denial of Service	6/25	Zamanlanm■■ cron, statik önbellek kullan■m■	Dü■ük
T8	Hata Bilgi S■z■nt■s■	Info Disclosure	6/25	Genel hata sarmalay■c■s■, stack trace gizleme	Yok

5. Web Güvenli■i Ba■l■klar■, ■zleme ve Olay Müdahalesi

Güvenlik Ba■l■klar■: Mozilla Observatory ≥ B+ ve SecurityHeaders ≥ A seviyesi hedeflenmi■tir. Tan■mlanan ba■l■klar: Content-Security-Policy (unsafe-inline ve unsafe-eval yasak), Strict-Transport-Security (max-age=31536000; preload), X-Content-Type-Options: nosniff, X-Frame-Options: DENY, Referrer-Policy: strict-origin-when-cross-origin, Permissions-Policy: camera=(), microphone=().
Güvenlik ■leti■imi: RFC 9116 uyumlu /.well-known/security.txt dosyas■ servise al■nm■■t■r.
■zleme ve Olay Müdahalesi: Cloudflare Workers Observability ile loglar toplanmaktad■r. Olas■ bir API anahtar■ s■z■nt■s■ durumu için 6 ad■ml■ (Tespit, ■ptal, Zarar Tespiti, Yenileme, ■nceleme, Bildirim) müdahale rehberi haz■rlanm■■t■r (bkz. RUNBOOK.md).

6. Maliyet Yönetimi ve Bütçe

Projenin bulut altyap■s■ Cloudflare Workers Ücretsiz Katman■ (günlük 100.000 istek) ve GitHub Actions (ayl■k 2.000 dk) üzerinde kurgulanm■■t■r. **Tahmini ve hedeflenen maliyet: 0 TL'dir.** Beklenmeyen kullan■m a■■mlar■na kar■■ Cloudflare Bildirim ve Bütçe Alarmlar■ devreye al■nm■■t■r.